Computerforensik

Dr. Stefan Hahndel

Sommersemester 2026

Technische Hochschule Ingolstadt
Fakultät für Elektrotechnik und Informatik

Vorstellung Dozent

Dr. Stefan Hahndel
Prof. für technische Informatik und Simulationssysteme

Fakultät für Informatik
Esplanade 10
80409 Ingolstadt
Telefon: (0841) 9348-3860
Fax: (0841) 9348-99-3860

Email: stefan.hahndel@thi.de

Stationen:

- 1992-1997: wiss. Mitarbeiter, ab 1996 wiss. Assistent an der TU München
- 1.1.1998-30.09.2001: Mitarbeiter der KPMG
  - Prokurist im Fachbereich Information Risk Management
  - Zahlreiche Securityaudits
- seit 01.10.2001 an der TH Ingolstadt

Gliederung von Teil 1 I

1. Einleitung und Grundlagen forensischer Wissenschaften
   - Lernziele der Veranstaltung
   - Klassische Forensik
   - Spuren
2. Computerforensik
   - Rechtliche Grundlagen und Datenschutz
   - Digitale Spuren
   - Typische Anwendungen dre Computerforensik
3. Anti-Forensik
4. Computerforensik Vorbereitungen
   - Organisatorische Vorbereitungen
   - Regelmäßige Maßnahmen
   - Technische Maßnahmen

Teil I

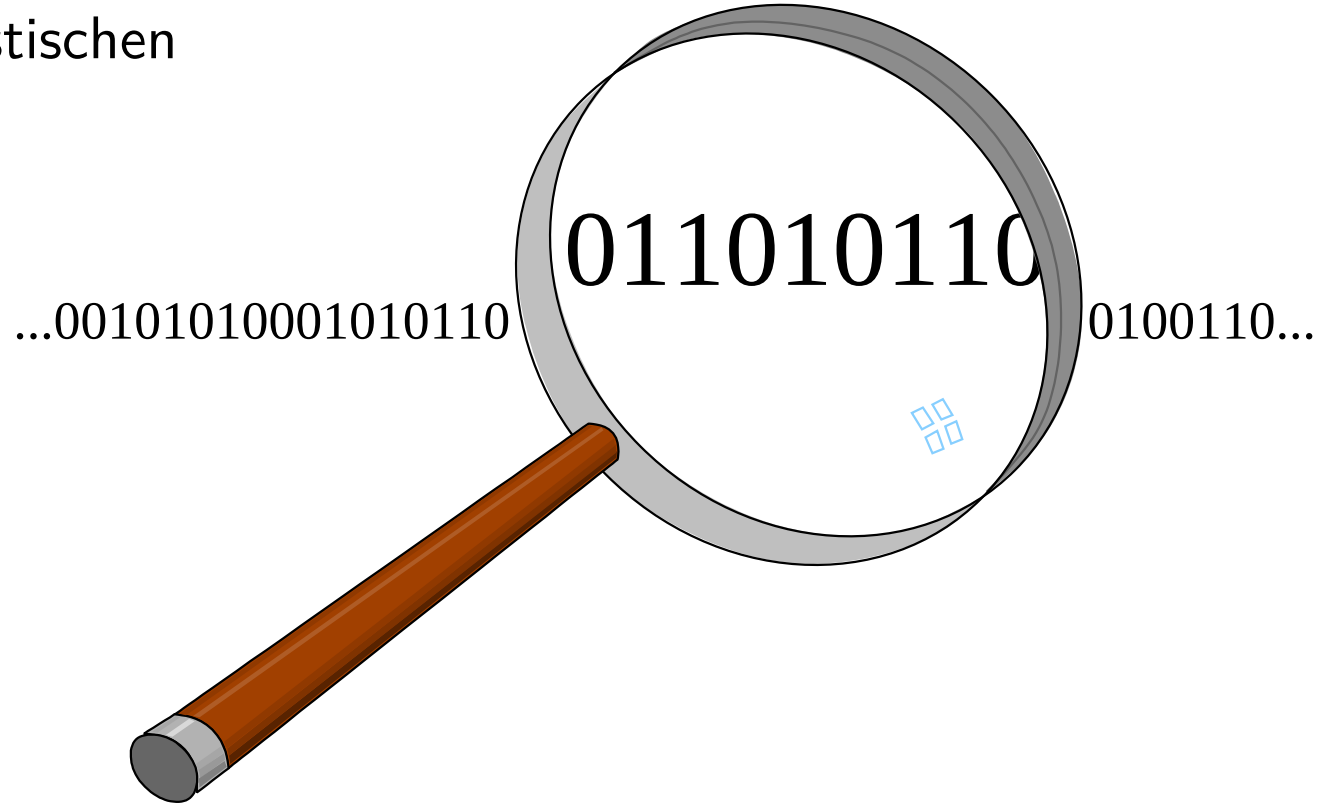
Einführung und Grundlagen forensischer Wissenschaften

Lernziele: Kenntnisse über

- Wissenschaftliche und theoretische Grundlagen der Computerforensik
- Methodisches Vorgehen bei IT-forensischen Analysen
- Aufbau typischer Werkzeuge zur Computerforensik
- Durchführung und Methodik forensischer Analysen
- Technische Grundlagen wichtiger Speicherklassen und Datenträger
- Grundlagen der Malwareanalyse kennen
- Aufbau und Analyse wichtiger Dateisysteme
- Analyse von Programmen
- Netzwerkforensik
- Anforderung an die Dokumentation

Welche Fragen stellt man sich die Forensik?

- Die 7 kriminalistischen Ws
  - Wer?
  - Was?
  - Wo?
  - Wann?
  - Warum?
  - Womit?
  - Wie?



Klassische Forensik

Die wissenschaftliche Methode

- Nutzung physikalischer Gesetzmäßigkeiten (Themodynamik, Impulserhaltung, Masse und Geschwindigkeit etc.)
- Experimente mit quantitativen Aussagen bestätigen oder wiederlegen Hypothesen
- Daraus Ableitung von Regeln

Gültigkeit der Regeln

- „Die Erde ist eine Scheibe“ lange Zeit gültige Regel
- Fingerabdrücke: Seit dem Anschlag von Madrid in Zweifel
- DNA-Tests: Auch hier erste Einschränkungen
- Aussagen basierend häufig auf Wahrscheinlichkeiten

Aussagekraft forensicher Wissenschaften

- Eine wissenschaftliche Methode genießt vor Gericht und in der Öffentlichkeit eine besonders hohe Glaubhaftigkeit
- Umgekehrt werden Aussagen oft erfolgreich diskreditiert, indem „unwissenschaftliche Methoden“ vorgeworfen werden
- Oft werden in forensischen Wissenschaften Zusammenhänge als richtig dargestellt, z.B. „die vorliegende Kugel wurde aus einer bestimmten Waffe abgefeuert“
- Im streng wissenschaftlichen Sinne ist diese Tatsache nicht beweisbar
- Nur wenn hinreichend häufig und mit adäquaten Methoden, versucht den Zusammenhang zu wiederlegen, gelangt man zur Überzeugung, der Zusammenhang sei wahr
- Tatsächlich aber ermittelt man nur den wahrscheinlichsten Tatbestand

Forensische Wissenschaften, Kriminalistik und Kriminologie

Man unterscheidet angewandte von reinen Wissenschaften Das „Handbuch der Kriminalistik“ (Groß und Geerds, 1977) unterscheidet 4 Bereiche:

1. Verbrechenstechnik

- „Modus Operandi“
- Sichtweise auf die rein technische Seite der Tatausführung
- Keine Betrachtung von Motiv und Beweggründen

2. Kriminaltechnik

- Erbringung von Sachbeweisen
- z.B. Klassische Spurensammlung: Fingerabdrücke, Schmauchspuren etc.

Forensische Wissenschaften, Kriminalistik/Kriminologie (2)

3. Kriminaltaktik

- Wie werden die Mittel der Kriminaltechnik am besten eingesetzt
- Anwendung sinnvoll, ökononisch, zulässig ?
- Bereich umfasst Tatortarbeit, Fahnung und Vernehmung

4. Organisation der Verbrechensbekämpfung

- Aufgabenaufteilung und Zusammenarbeit zwischen Behörden und Einzelpersonen
- Zusammenarbeit zwischen Polizei, Staatsanwalten und Gerichten
- Internationale Kooperationen

Abgrenzung Kriminalistik $\longleftrightarrow$ Kriminologie

Kriminalistik

- Orientierung an Natur- und Ingenieurwissenschaften
- Anwendung physikalischer/chemischer Zusammenhänge etc.
- Beispiele für relevante physikalische/chemische Gesetzmäßigkeiten?

Kriminologie

- Lehre von Ursache und Erscheinungsformen der Kriminalität
- Zuordnung in den Sozialwissenschaften und Psychologie
- z.B. Profiling etc.

In der Vorlesung wird eher (analog Freiling) der Begriff der forensischen Wissenschaften statt Kriminologie verwendet

Analyse von Spuren zur Identifizierung von Personen (1)

- Seit dem 17. Jahrhundert Besonderheiten von Fingerabdrücken bekannt
- Trotzedem bis zum späten 19. Jahrhundert Anthropometrie vorherrschend
  - Vermessung mehrerer Bereiche des Körpers
  - Alponse Bertillon (1883): Kombination dieser Messwerte ist individualisierendes Merkmal
- 1900 Nutzung von Blutgruppen durch Karl Landsteiner, Unterscheidung Tierblut von menschlichem Blut durch Pazl Uhlenhuth 1901
- 1903 Durchbruch der Daktyloskopie im Gefängnis von Kansas: Zwei Häftlinge konnten nur durch Fingerabdrücke unterschieden werden

Analyse von Spuren zur Identifizierung von Personen (2)

- Engländer Francis Galton (1822-1911) entwickelte das heute noch gültige Klassifizierungssystem der Daktyloskopie
- DNA-Analyse gilt heute als Meilenstein der Identifizierung von Personen
- 1980 von Sir Alex Jeffreys entschieden vorangetrieben
- DNA heute ebenso überzeugend angesehen wie vor 100 Jahren der Fingerabdruck

Zu beachten:

- Sowohl Fingerabdrücke, als auch DNA werden nur durch eine Reihe einzelner Merkmale identifiziert
- Damit ergibt sich nur eine hohe Wahrscheinlichkeit, kein eineindeutiger Nachweis

Enstehung von Spuren

Was ist eine Spur? - zunächst physische Betrachtung

- Wort Spur kommt ursprünglich aus dem Altgermanischen und bedeutet Tritt oder Fußabdruck
- In der Jägersprache spricht man von Fährte
- In der physischen Welt kann nahezu alles zu Spuren werden
  - Schon gehabt: Fingerabdrücke, DNA-Spuren, Fußabdruck
  - aber auch: Kleidungsfasern, Haare, Bruchmuster, Schleifspuren, ...
  - Kriminalistische Literatur klassifiziert Dutzende verschiedene

- Relevant sind hauptsächlich Spuren, die über Tathergang Aufschluß geben
- Besonders interessant: Spuren die unabsichtlich hinterlassen werden

Behandlung von Spuren

- Grad die relevanten Spuren oft schwer erkennbar
- Daher i.d.R. Spezialisten in allen Phasen beteiligt
  - Bei der Aufnahme und Konservierung von Spuren
  - Bei der Aufbereitung und Analyse der Spuren
  - Bei der Interpretation der Spuren
- Besonders wichtig dabei: Vernichtung oder Veränderung von Spuren vermeiden
  - In der Praxis: Nur wenige zulässige Personen dürfen den Tatort betreten
  - Verwendung von Schutzanzügen
  - Vollständige Dokumentierung der Verwahrungskette
  - Aufbewahrung in besonders geschütztem Raum,der Asservatenkammer

Klassifikation von Spuren

Klassifikationsarten nach Harris

- Klassifikation nach Straftat
- Nach chemischer oder biologischer Zusammensetzung
- Transiente Spuren:
  - Gerüche wie z.B. Benzin, Parfüm, oder Urin
  - Temperatur z.B. eines Motors, Wassertemperatur einer Badewanne, Körpertemperatur einer Leiche, etc.
  - Transiente Spuren werden nur schriftlich festgehalten
- Kirk (1974r, nicht der von der Enterprise ;-): Mikroskopische Spuren am wichtigsten, da von Täter und Ermittler oft übersehen
  - Beispiele: Pollen, Haare,etc.
  - Staubsauger heute daher wichtiges Utensil bei Spurensuche

Locards Austauschprinzip

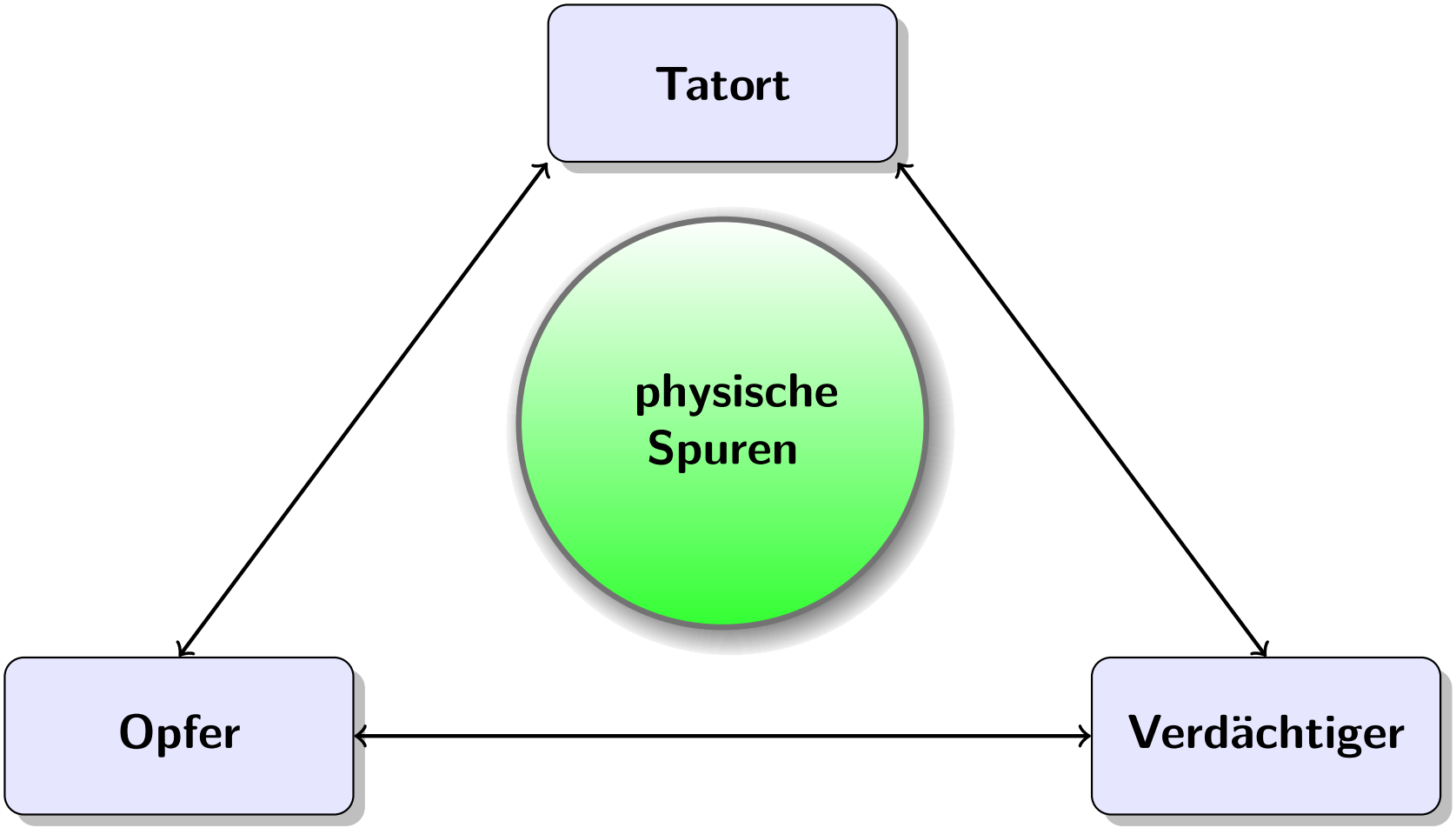
- Edmond Locard (1877-1966) war französischer Mediziner
- Formulierte eines der wichtigsten Grundprinzipien forensischer Wissenschaft
- Gründete 1910 in Lyon das erste europäische Institut für Kriminaltechnik

Locards Austauschprinzip

Jeder und alles am Tatort nimmt etwas mit und läßt etwas zurück

- Jede Berührung tauscht Stoffe aus (Blut, DNA-Spuren etc.)
- Basis für jede Spurensuche
- Was sind die Grundprinzipien ?
- Später ziehen wir einen Vergleich zu digitalen Spuren.

Schematische Darstellung von Locards Austauschprinzip



Theorie von Transfers und Zerteilbarkeit

Übertragung (Transfer) von Materie

- Das Austauschprinzip von Locard geht also von Austausch von Materie aus
- Notwendige Bedingung dafür ist die Zerteilbarkeit (Divisibility)
- Wesentlicher Teil der Forensik basiert auf dessen Prinzip

Übertragung von Mustern

- Heutzutage erweiterte Betrachtung des Austauschprinzips
- Betrachtet wird auch der Transfer von Mustern
- Bei Fußspuren, Reifenspuren, Rillenmustern etc. findet nur ein geringer Austausch von Materie statt, das Muster ist wesentlich

Rekonstruktion des Tathergangs

Ereignisse

- Aufstellung einer Menge von Hypothesen über den Tathergang
- Spuren, die auf den Prinzipien der Zerteilbarkeit und des Transfers beruhen sind ein Hinweis auf den Kontakt von Objekten
- Wenn feststeht, dass zwei Objekte in Kontakt waren, spricht man von einem Ereignis
- Rekonstruktion bedeutet nun, alle ermittelten Ereignsse in einen räumlichen und zeitlichen Zusammenhang zu bringen

- z.B. Person P war an Ort X (Fingerabdrücke gefunden)
- z.B. Schuh S war am Ort Y (Fußabdruck)
- z.b.Auto A war am selben Ort wie Person Q (DNA-Spuren von A am Auto)

Der Weg zur Assoziation

Assoziation

- Bezeichnet die Feststellung des Kontaktes zwischen zwei Objekten
- Ergebnis ist ein Ereignis

Beispiele:

- Zuordnung eines konkreten Schuhs zur Spur „Schuhabdruck“
- Zuordnung einer Kugel zur konkreten Waffe
- Zuordnung eines Fingerabdrucks zu einer konkreten Person

Teilweise automatisierbar:

- Abgleich mit Datenbanken, Nutzung statistischer Verfahren
- Mathematische Logik, Theorembeweiser, Constrainttechniken

Übergang Klassische Forensik $\longrightarrow$ Computerforensik

Können Sie sich vorstellen, daß Methoden der klassischen Forensik auch bei einem IT-System angewendet werden können? Klar, Sie denken an

- Fingerabdrücke auf Datenträgern
- DNA auf mobilen Geräten
- $\longrightarrow$ z.B. klassische Spuren auf Keylogger. Wer hat diesen in den Redaktionsräumen installiert?

Aber: Auch Kenntnis über den Aufbau von IT-Geräten kann wichtige Hinweise liefern.
Frage: Welche „Klassischen Spuren“ finden Sie an einem modernen Laserdrucker?

- Viele moderne, günstige Laserdrucker nutzen eine Transferfolie
- Auf dieser finden sich quasi Abbilder der gedruckten Seiten

Was ist Computerforensik?

Definition Computerforensik

Die Computer-Forensik (oder IT-Forensik oder Digitale Forensik) ist ein Teilgebiet der Forensik und bezeichnet die Untersuchung verdächtiger Vorfälle (Straftaten) bei denen IT-Systeme eine Rolle spielen.

- Dazu Erfassung, Analyse und Auswertung digitaler Spuren
- Ziel: Ermittlung von Täter, Tatbestand und Vorgehensweise
- Anwendungsgebiete: Netzeinbrüche, Finanz- und Steuerdelikte, Beschaffung und Besitz strafrechtlich relevanter Daten u.v.m.
- Dazu meist Suche nach Spuren auf Datenträgern, aber auch in flüchtigen Speichern, Netzwerkverkehr etc.

Was behandelt Computerforensik?

- Im Fokus steht ein digitales Gerät, das
  - dazu benutzt wurde, um ein physisches Verbrechen zu begehen oder vorzubereiten
  - Beispiele: Internetrecherche zum Bombenbau, Waffenkauf etc.
  - ein digitales Ereignis, das Policies oder Gesetze verletzt hat
  - Beispiele: Illegaler Zugriff auf Computer (Hacking), Erpressung per Email, Illegale Downloads, etc.

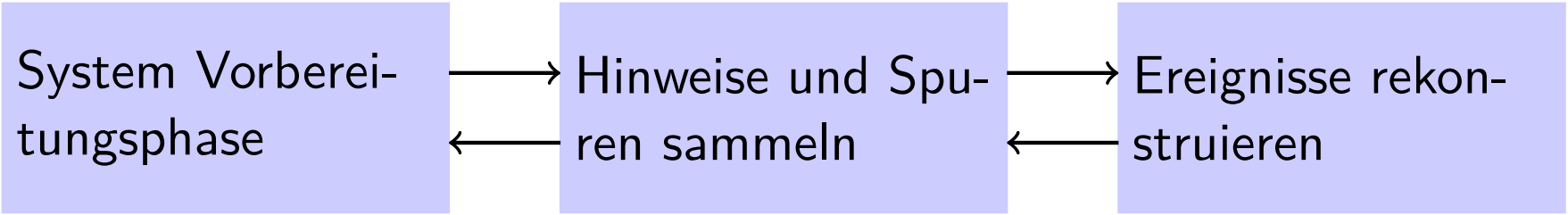
Digitale Ermittlung ist ein Prozeß

- Aufstellen und Prüfen von Hypothesen
- Suche nach Indizien oder Beweisen
- Forensik: Nutzung wissenschaftlicher Methoden oder Technologie in der Ermittlung, damit Beweise „gerichtsfest“ sind

Was sind typische Fragestellungen?

- Ist eine Person im Besitz illegaler Inhalte und wie hat die Person die Inhalte beschafft?
- Wer ist in Computer X eingedrungen und welche Werkzeuge wurden dazu benutzt und woher kam der Angreifer?
- Wer hat den Netzwerkverkehr von Person X aufgezeichnet?
- Wann wurden wo welche Fotos gemacht?
- Wer hat im Unternehmen vertrauliche Dateien geleaked?
- Welche Person hat eine bestimmte Summe unterschlagen?
- Wie ist ein bestimmtes Schadprogramm aufgebaut ?
- Finden sich bei einer Software (z.B. Schadprogramm) Hinweise auf den/die Urheber?
- Ist Software A ein Plagiat von Software B?
- Fallen Ihnen weitere Beispiele ein?

Prinzipielle Vorgehensweise



- Systemvorbereitungsphase: Systemzustand soweit möglich „einfrieren“ und soviel wie möglich vom Systemzustand sichern
- Hinweise und Spuren sammeln: Suche nach digitalen Spuren
- Assoziation, um Ereignisse zu rekonstruieren

Wdh: Strafrechtliche Grundlagen in Deutschland

§202 StGB	Ausspähen von Daten
§263 StGB	Computerbetrug
§269 StGB	Fälschung beweiserheblicher Daten
§270 StGB	Täuschung im Rechtsverkehr bei DV
§271, §274 Abs.1 Nr.2, §348 StBG	Falschbeurkundung / Urkundenunterdrückung im Zusammenhang mit DV
§303a StGB	Datenveränderung
§303b StGB	Computersabotage

Welche Daten sind evt. Gegenstand der Computerforensik?

- Buchungen in ERP-Systemen
- Protokolldateien
- E-Mails
- Chat-Protokolle
- Office-Dokumente
- Netzwerkmitschnitte

Problem: "Personenbezogene Daten"gemäß Art. 4 Nr. 1 DSGVO

- Angaben über persönliche oder sachliche Verhältnisse
  - einer bestimmten oder bestimmbaren natürlichen Person
  - offensichtlich: Name, Geburtsdatum, Gehalt, ...
  - nicht offensichtlich: Nutzerkennungen, IP-Adressen usw.

Art. 6 DSGVO (Erlaubnisvorschrift)

Eine Verarbeitung personenbezogener Daten ist nur rechtmäßig, wenn mindestens eine der folgenden Bedingungen erfüllt ist:

1. Einwilligung der betroffenen Person in die Verarbeitung ihrer Daten
2. Erfüllung eines Vertrags mit der betroffenen Person oder Durchführung vorvertraglicher Maßnahmen auf Anfrage der betroffenen Person
3. Erfüllung einer rechtlichen Verpflichtung, der der Verantwortliche unterliegt
4. Schutz lebenswichtiger Interessen der betroffenen Person oder einer anderen natürlichen Person
5. Wahrnehmung einer Aufgabe, die im öffentlichen Interesse liegt oder in Ausübung öffentlicher Gewalt erfolgt, die dem Verantwortlichen übertragen wurde
6. Berechtigte Interessen des Verantwortlichen oder eines Dritten, sofern die Interessen oder Grundrechte und Grundfreiheiten der betroffenen Person nicht überwiegen

Datenschutz bei internen Untersuchungen

- Einbindung des betrieblichen Datenschutzbeauftragten
- Einbindung des Betriebsrats oder des Sprecherausschusses
- Informationspflicht gegenüber der betroffenen Person
  - Nur wenige Ausnahmen
  - Z. B. bei konkretem strafrechtlichem Verdacht mit Vertuschungsgefahr
  - Dazu aber in der Regel richterlicher Beschluss nötig

Grundsätzlich gilt immer:
Datenerhebung sollte auf den vereinbarten Zweck beschränkt sein, und es gilt der Grundsatz der Datensparsamkeit.

Beispiele für strukurierte und unstrukturierte Daten

Strukturierte Daten

- Auswertungen aus ERP-Systemen, Finanzbuchhaltung
- Daten aus Lagerhaltung
- Tabellen aus Datenbanken
- Merkmal $\longrightarrow$ Format leicht exportierbar und auswertbar

Unstrukturierte Daten

- Chatprotokolle, Emails
- Logdateien, Officedokumente

Unterschiedliche Herangehensweisen

Relativ unproblematisch: Strukturierte Daten

- Personenbezogene Daten leichter abgrenzbar
- In der Praxis: Anonymisierung oder Pseudonymisierung

Anonymisierung

Aus den Daten kann überhaupt nicht mehr auf die Person geschlossen werden.

- z.B. vollständige Entfernung aller Identifikationsmerkmale
- z.B. nicht rückverfolgbare Subsitution der Identifikatoren

Pseudonymisierung

Rückschluß auf tatsächliche Person nur unter sehr hohem Aufwand

- Löschung nicht aller identifizierbaren Merkmale
- Aggregation von Daten

Pseudonymisierung - Originaldaten

Patient	Krankenkasse	Abr.nr.	Datum
Zacharias	KGes	5233	28.02.2015
Mayerlein	Bamb	5234	28.02.2015
Zacharias	KGes	5235	02.03.2015
Amberger	Bamb	5236	02.03.2015
Kleinlein	privat	5237	03.03.2015
Mayerlein	Bamb	5238	03.03.2015
Mirkowski	KGes	5239	04.03.2015
Zacharias	KGes	5240	04.03.2015

DSGVO ist nur auf personenbezogene Daten anwendbar

Pseudonymisierung - Pseudonymisiert

Patient	Krankenkasse	Abr.nr.	Datum
Id243923	KGes	5233	28.02.2015
Id636843	Bamb	5234	28.02.2015
Id243923	KGes	5235	02.03.2015
Id875368	Bamb	5236	02.03.2015
Id166743	privat	5237	03.03.2015
Id636843	Bamb	5238	03.03.2015
Id435595	KGes	5239	04.03.2015
Id243923	KGes	5240	04.03.2015

Genügt dies der Datenschutzgrundverordnung (DSGVO)?

Vor- und Nachteile von Pseudo- oder Anonymisierung

Vorteile

- Ermöglichen (juristisch) oft erste die Auswertung von Daten
- Akzeptanz steigt bei betroffenen
- Datenaggretation oft ergänzend $\longrightarrow$ Beschleunigung der Auswertung

Nachteile

- Pseudonymisierung: Häufig Rechtsunsicherheit wegen Ermessensspielraum, ob diese als ausreichend betrachtet wird.
- D.h. Bei Pseudonymisierung gilt auch das DSGVO, wenn auch eingeschränkt
- Anonymisierung entfernt oft genau die relevanten Daten

Mitwirkung von Dritten

- Differenzierung hinsichtlich Zuordnungsvorschrift
- Unternehmen / Behörden geben oft Daten zur forensischen Untersuchung an Dritte
- Pseudonysierte Daten unterliegen auch der DSGVO und dürfen zur die Zwecke verarbeitet werden für die sie pseudonymisiert wurden. Der Dritte darf keine Kenntnis zur Zuordnungsvorschrift haben

Rückübermittlung der Ergebnisse

- Analysehandlungen unterliegen grundsätzlich der DSGVO
- Insbesondere ist hier Art. 6 Abs. 1 f) DSGVO zu beachten

Problem bei unstrukturierten Daten

- Anonymisierung häufig schwierig
- Wie anoymisiert man z.B.
  - Emails, Chatprotokolle ?
  - Officedokumente ?

Welche Probleme sehen Sie dabei?
Vorgehensweise?
Chat-Protokolle lt. LAG Hamm (2012) rechtlich + wie EMail zu behandeln.
Rechtlich bisweilen umstritten: Bei geeigneter Formulierung von Arbeitsverträgen, Betriebsvereinbarungen, etc. DSGVO ausgehebelt und Einwilligung nicht erforderlich?

Digitale Spuren

Digitale Spuren

Digitale Spuren (engl. digital evidence) sind nach Casey alle Spuren die auf Daten basieren die auf IT-Systemen gespeichert oder übertragen wurden

- Digitale Spuren sind zunächst physische Spuren
  - Magnetisierung auf Festplatte
  - Elektromagnetische Wellen
  - Ladungszustände etc.
- Digitale Spuren müssen zunächst extrahiert und in lesbare Form gebracht werden
- Problem digitaler Spuren?

Digitale Spuren und Abstraktion

- Digitale Spuren benötigen Werkzeuge zur Aufbereitung
- Werkzeuge liefern aber nur eine Abstraktion bzw. Interpretation der physischen Spuren
- Abstraktionen können mehrere Abstraktionsebenen enthalten
- Jede Abstraktionsebene kann wieder eigene Interpretationsfehler enthalten
- Beispiele?

Beispiel einer Email-Datei

Eine Emaildatei entsteht durch

1. Interpretation der Magnetisierung der Festplatte (Bits)
2. Interpretation der Bits anhand Zeichencodierung
3. Interpretation der Zeichen anhand Dateisystem
4. Interpretation der Daten des Dateisystems als zusammenhängende Datei
5. Interpretation der Datei als Email oder Sammlung von Emails in Abhängigkeit des Mailformats

Transfer digitaler Spuren

- Locards Transferprinzip gilt in der digitalen Welt nur eingeschränkt.
  - Was bedeutet es in der digitalen Welt, dass „Kraft auf ein digitales Objekt einwirkt?“
  - Digitale Objekte selbst können atomar (im Sinner von unzerteilbar) sein
- Beispiel: „Kopieren von Dateien“
  - Dateien bestehen aus vielen kleinen Festplattenblöcken
  - Löschen von Dateien hinterlässt Spuren
- Beispiel: „Aufruf von Systembefehlen“
  - Aufruf hinterlässt Einträge in History- und/oder Logdateien etc.

Manipulierbarkeit digitaler Spuren

- Digitale Spuren sind sehr leicht manipulierbar
- Absichtlich
  - durch Straftäter
  - durch Ermittler
- Unabsichtlich durch Ermittler
- Manipulation hinterläßt unter Umständen keine unmittelbar sichbaren Zeichen

Digitale Spuren sind nicht personenbezogen

- Digitale Spuren sind zunächst getrennt von der physischen Welt
- Zuordnung von digitalen Spuren zu einer realen Person nur durch starken Authentifizierungsmechanismus möglich
- Ausschliessliche Beweisführung nur über digitale Spuren nicht durchführbar
- zusätzliche nicht-digitale Spuren nötig
- Oft liefern aber digitale Spuren erst wichtige Hinweise auf nicht-digitale Spuren

Positive Eigenschaften digitaler Spuren

Duplizierbarkeit

- Untersuchung auf Kopie schont Original
- Übereinstimmung Kopie und Original nachweisbar
- Untersuchungen reproduzierbar

- Manipulationen können durch Vergleich mit Originalkopie nachgewiesen werden
- Digitale Spuren werden häufig nicht gründlich vernichtet
  - Wiederherstellbarkeit gelöschter Dateien
  - Notfalls Rückgriff auf physische Spuren (Magnetisierung)

Komplexität digitaler Spuren

- Komplexität
  - Verschiedene Geräte und Betriebssysteme
  - Unterschiedlichste Datenformate
  - Verschiedene Versionen
  - Jedes System ist damit anders
  - Niemand hat Gesamtüberblick
- Digitale Spuren entstehen heute quasi überall, d.h. es ist in der Praxis kaum möglich alle Spuren zu einer Straftat zu beseitigen
- Locards Austauschprinzip gilt also eingeschränkt

Wo fallen digitale Spuren an?

- LOG-Dateien, Caches
- Backups
- An vielen Stellem im Dateisystem
- Überwachungskameras
- Sogar auf Digitalfotos (Welches Foto gehört zu welcher Digicam?)
- Abrechnungsdaten Telefon, Internet
- Routerlogs
- Registry
- Swapspace
- Handy
- Datenträger
- ...

Typische Szenarien in der Unternehmens-IT

- Welche Gefahren und Anwendungen fallen Ihnen dazu ein?
- Wie bewerten Sie diese hinsichtlich Wirkung und Vorgehensweise?
- Wie gut kann man diese Szenarien vorbereiten?
  - hinsichtlich Prävention
  - hinsichtlich einer möglichen Aufklärung, falls es doch passiert

Allgemeine Anwendung

- Anwendung im öffentlichen und privaten Bereich
  - Viren, Würmer
  - Installation von Trojanern
- Direkte Angriffe durch Hacker oder Cracker
- Strafrechtlich relevanter Mißbrauch des Internetaccounts
- Ausspähen und Mißbrauch von Daten
- Absichtliches verändern geschützter Daten
  - z.B. Sabotage Löschung von Daten
  - „Unterschlagung“, persönliche Vorteilsnahme per Computer
  - z.B. Rückdatierung von Verträgen
- Installation von Hintertüren, z.B. Rootkit mit Backdoor

Offizielle Sichtweise von Unternehmen

- Unternehmen stellen oft Umgestaltung von Webseiten (Defacement) als ihr Hauptproblem dar
  - Imageverlust für das Unternehmen
  - Meist betonen Unternehmen, es sei nichts passiert,
- Andere Risiken inzwischen an der Tagesordnung:
  - Klau von Kreditkartendaten
  - Gezielte Industriespionage
  - Verrat von Ideen, Patenten etc. durch eigene Mitarbeiter
  - Flächendeckendes auspähen von Daten
- Zu Risikoanalysen siehe http://www.ists.dartmouth.edu/

Dimension aktueller Beispiele (1)

- 2017: WannaCry-Ransomware legt weltweit hunderttausende Systeme lahm (u.a. NHS in Großbritannien)
- 2017: NotPetya-Angriff verursacht massive Schäden bei Unternehmen (z.B. Maersk, Merck)
- 2020: SolarWinds-Hack (Supply-Chain-Angriff) kompromittiert zahlreiche Behörden und Unternehmen weltweit
- 2021: Colonial Pipeline Ransomware-Angriff führt zu Treibstoffengpässen in den USA

Dimension aktueller Beispiele (2)

- 2021: Log4Shell-Sicherheitslücke in Java Log4j betrifft Millionen Systeme weltweit
- 2022: Uber-Hack durch Social Engineering (MFA Fatigue), Zugriff auf interne Systeme
- 2023: MOVEit-Transfer-Schwachstelle führt zu massiven Datenlecks bei Unternehmen und Behörden
- 2024: Cloud-Leaks und KI-bezogene Angriffe (z.B. Datenabfluss aus Trainingsdaten und APIs)

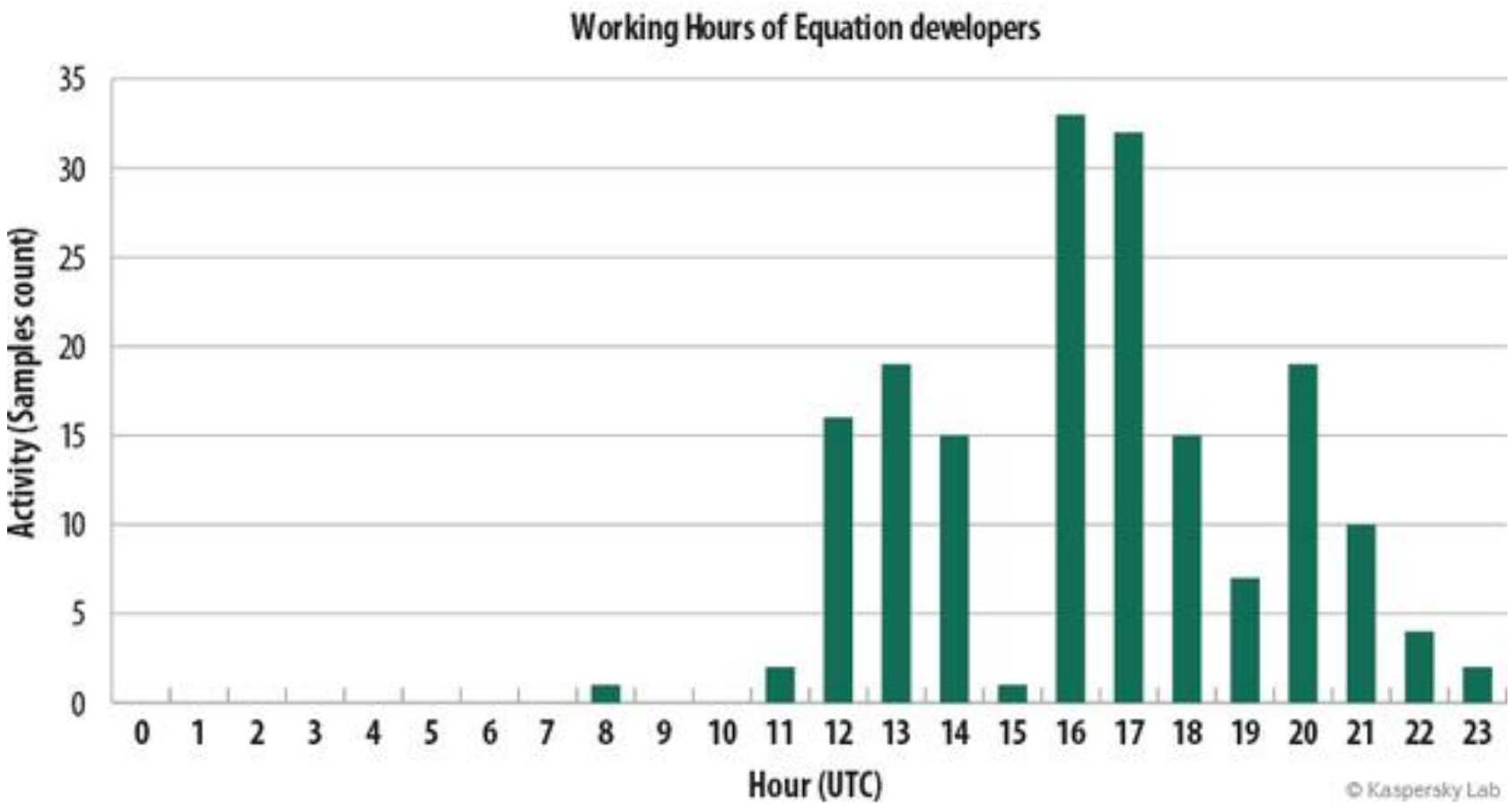
Forensische Analyse aktueller Angriffe

- Ransomware (WannaCry, NotPetya): Analyse von Speicherabbildern, Dateisystemartefakten, Verschlüsselungsroutinen, Netzwerkverkehr
- Supply-Chain-Angriffe (SolarWinds): Untersuchung von Update-Mechanismen, Code-Signaturen, Build-Umgebungen, Log-Korrelation
- Schwachstellen (Log4Shell, MOVEit): Log-Analyse (Webserver, Applikationen), Rekonstruktion von Exploit-Ketten, IOC-Analyse (Indicators of Compromise)
- Social Engineering (Uber): Analyse von Authentifizierungslogs, MFA-Events, Benutzerverhalten (UEBA)
- Cloud- und KI-Angriffe: API-Logs, Zugriffstoken, Datenabflussanalyse, Modell- und Trainingsdatenforensik

Beispiel Schadcodeanalyse: Trojaner der Equation Group (EG)

- 2014 wurde von Kaspersky der Trojaner der Equation Group entdeckt
- Vermutung: Urheber die Geheimdienste der Five Eyes
- Analyse sehr schwer, da Schadcode hochkomplex
- Komplexität und erste Funktionalitäten weisen auf mathematisch hohe Kompetenz der Entwickler hin, daher der Name Equation Group
- Vorgehensweise u.a.: Suche nach Textstrings und Zeitstempel
- Vermutung Kaspersky: Hinweis auf NSA wg. String BACKSNARF_AB25 (Ein solches Projekt taucht in den Snowden Dokumenten auf) → war schon bekannt
- Nüchterne Betrachtung: Im Prinzip jeder Trojanerentwickler absichtlich solche Zeichenktten verwenden kann

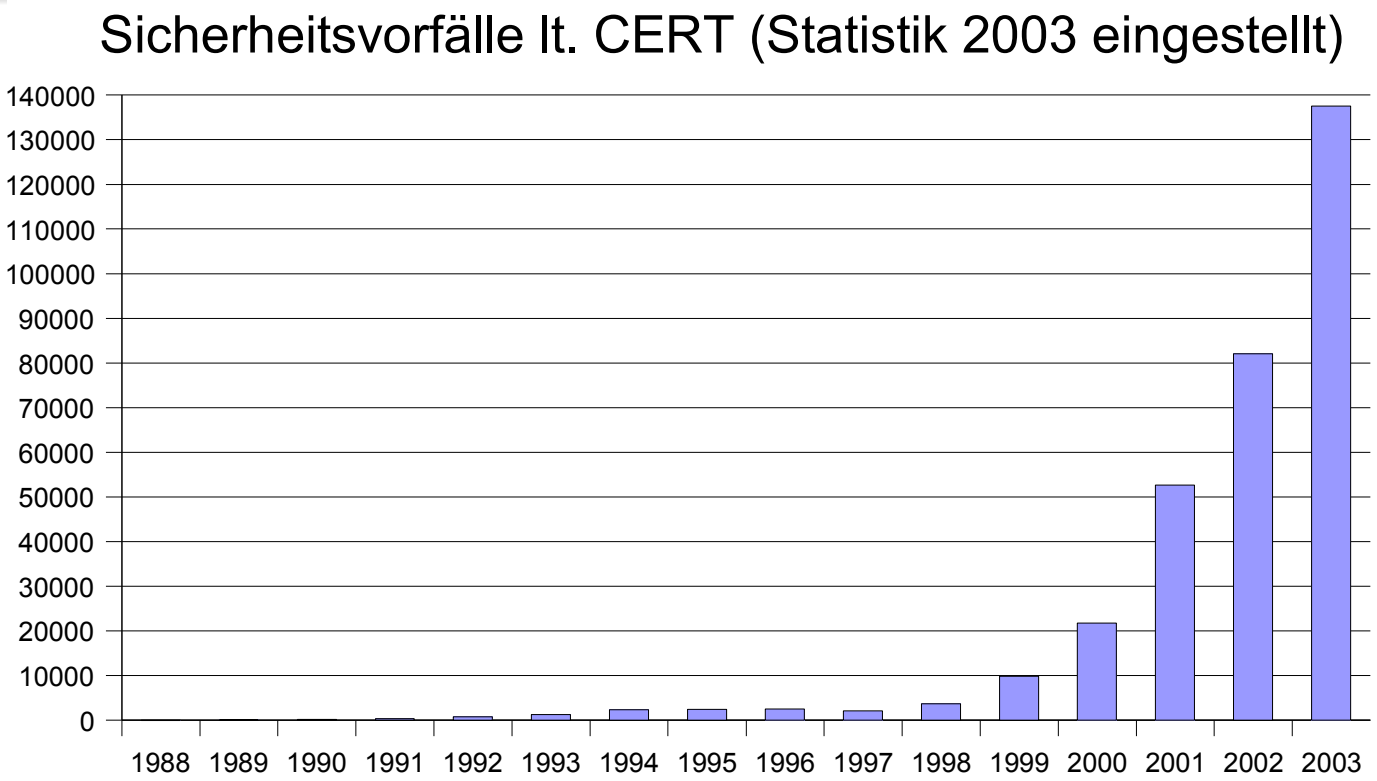
Arbeitszeiten der Entwickler von EG



Häufigkeit solcher Vorfälle

- Zuverlässige Statistiken über das umgehen von Sicherheitsmassnahmen sind schwer zu bekommen
- Quellen:
  - CERT (Computer Emergency Response Team) http://www.cert.org
  - Computer Crime and Security Survey des CSI, unter http://www.gocsi.com/press
  - Studien und Unternehmensumfragen von Beratungsgesellschaften wie z.B. KPMG, Ernst&Young, ...
- Verschiedene Quellen sagen auch aus:
  - 80 Prozent der IT-Angriffe auf Unternehmen finden durch Innentäter statt!
  - (Dies muss auch entsprechend berücksichtigt werden!)

Sicherheitsvorfälle



(Ältere Graphik, soll aber nur exponentiellen Anstieg zeigen)
Neuere Entwicklungen siehe z.B.: Lagebilder BKA

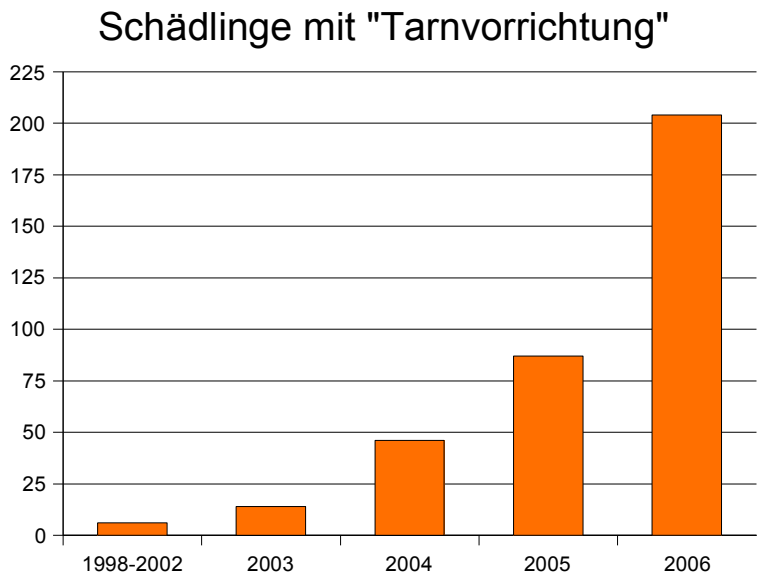
Rootkits - Die wachsende Gefahr

- Immer mehr Schädliche mit Rootkitfunktionalitäten ausgestattet
- Erschweren die Onlineanalyse befallener Systeme erheblich

Name	BS	Entdeckung
Troj/RusDrp-I	Windows	16-Jan-2007
Troj/Rustok-N	Windows	16-Jan-2007
Troj/Rustok-M	Windows	16-Jan-2007
W32.Sality.X	Windows	12-Jan-2007
Troj/RKRustok-K	Windows	12-Jan-2007
Troj/Mailbot-BG	Windows	12-Jan-2007
Troj/Haxdoor-DM	Windows	11-Jan-2007

Anzahl Schädlinge mit Rootkit

- Früher oft Unix/Linuxsysteme betroffen
- Heute meist Windows
- Programmierung durch Modulierung in BS erleichtert
- Quelle: http://www.antirootkit.com/



Begriffe (Wdh. aus IT-Sicherheit)

Scriptkiddies

- die häufigste Variante, zumeist jüngere Leute die im Internet nach fertigen Skripts und Werkzeuge suchen, um in Systeme einzudringen
- Wenig Fachwissen über Betriebssysteme und interne Abläufe
- Daher aber auch besonders gefährlich, richten leicht Schäden an
- Schutz gegen Skriptkiddies relativ einfach: Systeme auf aktuellem Stand halten, bekannte Sicherheitslücken schließen!
- Aufklärung mit Mitteln der IT-Forensik häufig (relativ) einfach

Begriffe

Hacker

- Meist Täter mit hohem Sachverstand, betreiben Systemeinbruch als „Sport“, richten eher selten tatsächlich Schaden an
- Teilen gefundene Sicherheitslücken häufig mit

Cracker (hatte ursprünglich andere Bedeutung)

- betreiben „ihr Geschäft“ in böswilliger Absicht
- Sabotage, Deaktivierung bestimmter Dienste, Verändern von Informationen Industriespionage
- Rechner für weitere Angriffe nutzen
- Inzwischen häufig als Auftragsarbeit mit finanziellem Interesse

Trends und künftige Entwicklungen

- Verstärkt organisierte Kriminalität in der IT
- Vorgehen und Werkzeuge immer professioneller
  - z.B. wachsender Einsatz von Bot-Netzen
  - Schadprogramme tarnen sich besser (Root-Kits)
- Künftige Entwicklungen
  - Einsatz von Virtualisierungstechniken bei übernommenem Rechner
  - Infizierte Firmware (z.B. bei Netzwerkkarten) übersteht selbst Neuinstallation des BS
  - Angriffe über VoIP-Systeme
  - Denkbar auch modifizierte CPU-Befehle (über Microcodepatches)

Anti-Forensik

Definition Anti-Forensik

Unter Anti-Forensik versteht fasst man alle Handlungen und Werkzeuge zusammen, die dazu geeignete sind IT-Forensische Untersuchungen zu verhindern oder zumindest zu erschweren.

Was fällt Ihnen dazu spontan ein?

- Klar, das einfachste: Verschlüsselung
- Verstecken von Daten. Wie ?
- Löschung von Daten
- Werkzeuge die Forensiktools selbst angreifen

Fallen Ihnen dazu Beispiele ein ?
Wie könnte das realisiert werden ?

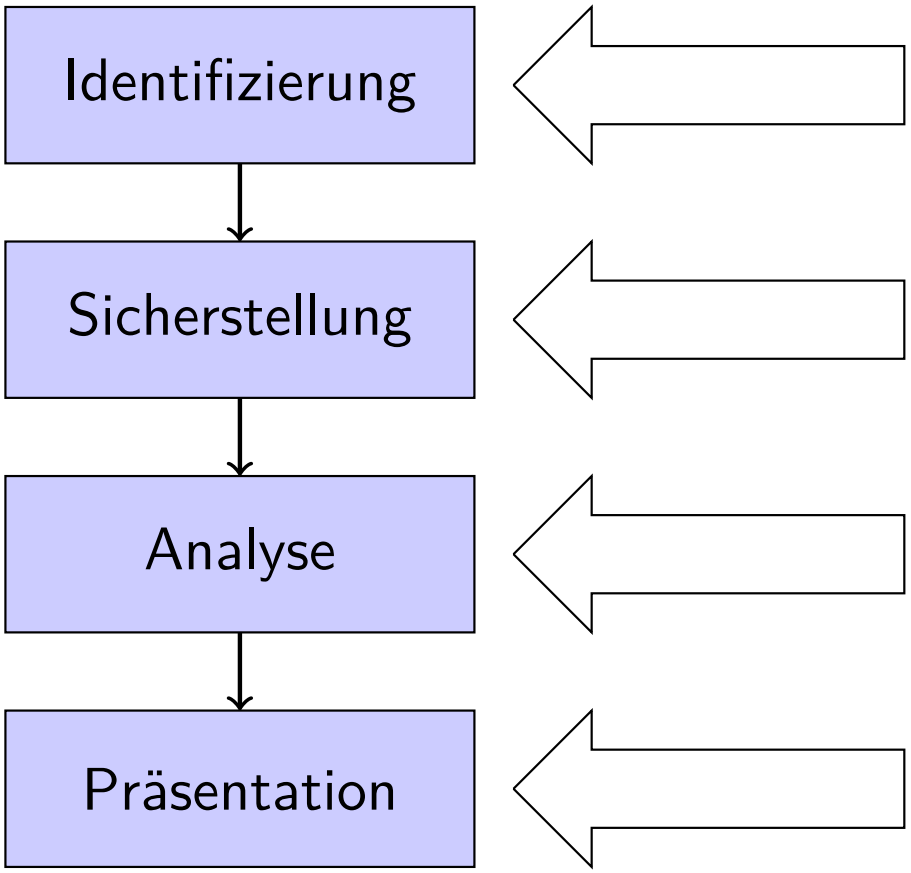
IT-Forensik mit angreifbaren Tools

Szenario:

- Ein Sachverständiger präsentiert vor Gericht seinen Bericht
- Die Gegenseite führt dann im Gericht live vor, dass die verwendete Software bei ein wenig präparierten Beispieldaten
  - ganze Bereiche übersieht
  - neue Daten in den Bericht einfügt
  - den Untersuchungs-PC trojanisiert

Wird das Gericht dem Gutachten dann noch trauen ?

Klassifikation Anti-Forensik



z.B. Steganographie

z.B. Bildschirmschoner mit Passwort, Verschlüsselung allg.

z.B. Schadcode zur Manipulation der Analyse-Software, zip-Bombe

z.B. Integration von Schadcode zur Modifikation von Reports

Beispiel für aktive Angriffe auf Forensiksoftware

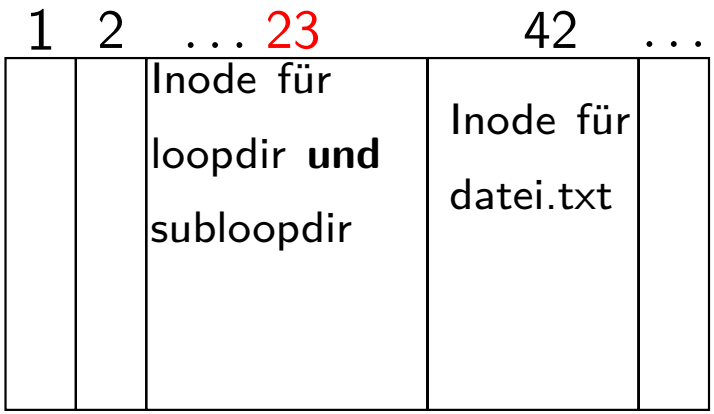
Archivbomben (auch Dekomprimierungsbombe):

- Zweck: Erzeugen übergrosser Dateien oder Endlosrekursion
- Inhalt z.B. Textdatei mit immer wiederkehrendem Muster
- spezielle zip-Datei die beim Entpacken wieder sich selbst erzeugt

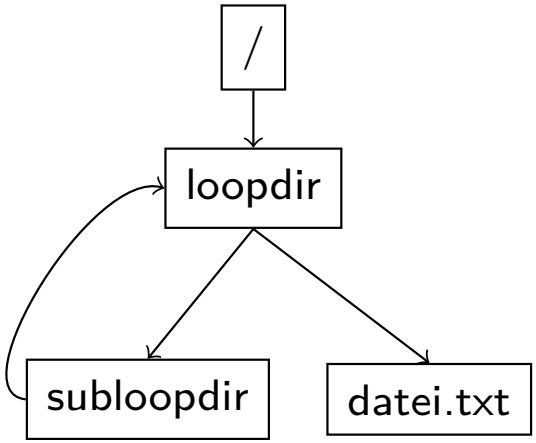
Rekursionen in Dateisystemen

- z.B. Verzeichnisschleife in ext2
- Zwei Verzeichnisse, z.B. loopdir und subloopdir unter der gleichen Inode-Nr. verwalten
- Sobald die Software subloopdir öffnet, landet sie wieder in loopdir, etc.

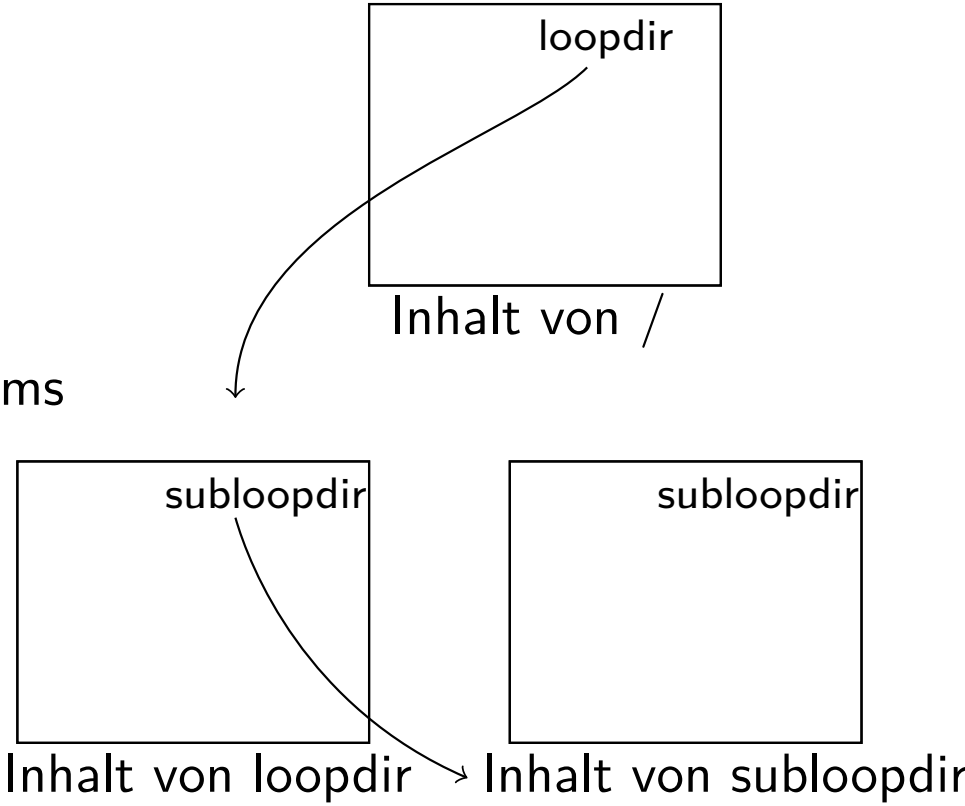
Endlosrekursionen in Dateisystemen



Inodetabelle eines Unixdateisystems



Verzeichnisbaum



nach Quelle: iX Kompakt Security 2014, S.101

Kategorisierung von Maßnahmen zur Anti-Forensik

Angriffsziel	Untersuchung vermeiden	Untersuchung verzögern
auf das Asservat bezogen	Festplatte und Registry wipen, Steganographie, vollständige Verschlüsselung, Kernel-Rootkits, Trigger	große Datenmengen (z.B. zig TB), ungewöhnliche Hardware
auf Auswertung bezogen	Präkontamination mit Auswerterdaten	Zeitstempel manipulieren
auf das Auswertesystem bezogen	Code-Injection, Buffer- bzw. Heap-Overflows, Format-String Attacken, Directory-Loop-Angriffe	Archiv-Bomben, Manipulation Hash-DB,

Praxis: Bugs in Forensik-SW, Fehler/Absturz auch ohne Manipulation.

Praxisbeispiel iX-Newsmeldung vom vom 21.12.2013

- „Ditto Forensic FieldStation“ von CRU Wiebetech
- Hardware-Writeblocker mit komplexer Firmware, u.a. integrierter Web-Server
- IT-Forensiker Martin Wundram fand mehrere Schwachstellen
  - keine speziellen Techniken für den Schreibschutz implementiert
  - Gerät ließ sich trojanisieren und für Angriffe missbrauchen
  - Cross-Site-Scripting-Schwachstellen (XSS) im internen Bereich der Weboberfläche
  - Angreifer konnten ohne Kenntnis einer gültigen Benutzerkennung Schadcode in die Oberfläche einfügen
  - Aktiver SSH-Server, Benutzerkonten sind jedoch deaktiviert
  - Webserver Lighthttpd in diesem Gerät mit vollen Root-Rechten betrieben

Inzwischen wurde die Firmware mehrmals nachgebessert

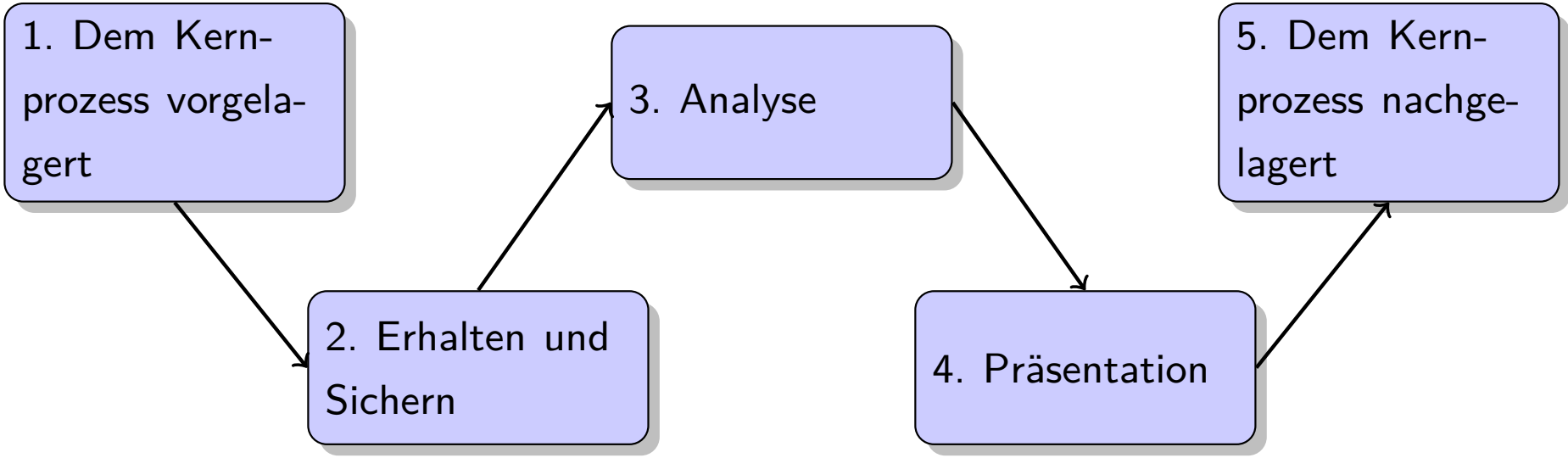
Praxiserfahrungen

- Keine aktuellen bzw. vollständigen Dokumente über alle Endgeräte
- Keine Dokumentation, wer zu welchem Zeitpunkt welches Endgerät benutzt hat
- Oft erst neue Bestandsaufnahme erforderlich
  - Entweder manuelle Inventur (sehr, sehr aufwändig!)
  - Einsatz automatisierter Tools (qualitätsabhängig)
- Neuer Begriff dazu: IT-Forensic Readyness
- Dazu standardisierte, einheitliche Verfahren erforderlich

Organisatorische Vorbereitungen

- Bewusstsein (Awareness) bei beteiligten Mitarbeitern und Verantwortlichen schaffen, daß ein Sicherheitsvorfall jederzeit an jeder Stelle auftreten kann.
- Vorplanungen:
  - Monitoring: Festlegung, welche Daten gesammelt und ausgewertet sollen und dürfen (Datenschutz!)
  - Erstellung eines Überwachungs- und Alarmierungskonzeptes: Wer darf was wann auswerten? Wer wird bei einem Vorfall informiert?
  - Weiterbildung: Sicherheitsbeauftragte und Admins sollten mit Incident Responsetechniken und Forensiktools vertraut sein.
- Gut dokumentierte Verfahren für Änderungen an Soft- und Hardware

Generisches Modell für Vorbereitungen



Vorbereitung, Erhaltung und Sicherung

Dem Kernprozess vorgelagert

- Erhebung Infrastruktur, Identifizierung wesentlicher Datenquellen
- Sensibilisierung, Erkennung wesentlicher Sachverhalte,
- Rechtliche Voraussetzungen und Freigaben
- Koordination und Planung der Logistik und Werkzeuge
- Einsatzbereitschaft und Test

Erhaltung und Sicherung

- Umsetzung und Anpassung der Planung
- Konkrete Identifikation zu sichernder Daten
- IT-forensische Sicherung
- Dokumentation und Beweismittelmanagment
- Lagerung und Beweismittelkette

Analyse und Präsentation

Analyse

- Sichtung - Ersteinschätzung - Priorisierung
- Identifikation relevanter Datenspuren
- Hypothesen, Datenanalyse $\longrightarrow$ Interpretation
- Zeitleistenerstellung, Korrelationen Datenspuren
- Täterprofile, Bereitstellung entspr. Dokumente

Präsentation

- Abschließende mündliche oder schriftliche Berichterstattung
- Sachverständigengutachten
- Gerichtsverfahren, Beweismittelverwertung, Beweisführung
- Einwände der Gegenseite

Nachbereitung

Nachbereitende Maßnahmen

- Projektabschluß
- Informationsweitergabe, Reviews
- Datenrückgabe / Löschungen
- Archivierung, Handlungsempfehlungen umsetzen

Bestimmung eines Response Teams

- Leiter / Stellvertreter
- Spezialisten mit fundierten Kenntnissen der lokalen IT-Infrastruktur
  - z.B. Serveradmins, DB-Admin, etc.
  - z.B. Netzwerkadmins
  - z.B. SW-Entwickler, falls Individual-SW im Einsatz
- Sicherheitsspezialisten, die mit Schwachstellen und Angriffsmethoden auf IT-Systeme vertraut sind
- Forensikspezialist (oder geschulter Admin) für Erfassung und Behandlung des Vorfalls (z.b. Imageerstellung, Daten sichern, etc.)
- Unterstützungspersonal
  - Schriftliche Dokumentation
  - Meldungen erfassen und dokumentieren

Fähigkeiten / Eigenschaften der Mitglieder

- „Stresserprobt“: ruhige Vorgehensweise unter Zeitdruck, Priorisierung von Tätigkeiten nach Dringlichkeit
- „Diszipliniert“: Einhaltung festgelegter Verfahren und genaue beweiskräftige Dokumentation
- Teamfähigkeit:
  - Kommunikationsfähigkeiten
  - Einschätzung von Fähigkeiten
- Lernbereitschaft: Motivation, sich ständig weiterzubilden
- Verschwiegenheit: Untersuchungsergebnisse sollten unbedingt vertraulich behandelt werden
- Logisches Denkvermögen: Gute Fähigkeit zu Schlußfolgerungen um aus Fakten korrekte Schlüsse zu ziehen

Anforderungen an Leiter

- Globale Unternehmenssicht
  - Kenntnisse der IT-Infrastruktur
  - Kenntnisse über wesentliche Geschäftsprozesse
- Weisungsbefugnis oder guten Draht zum Management
- Gute Entscheidungsfähigkeit
- Gute Koordinationsfähigkeiten
- Integrität / Zuverlässigkeit
- Leiter kann in Abhängigkeit des Vorfalls bestimmt werden
  - Kriterien für Auswahl ggf. schon vorab definieren
  - z.B. Netzwerkangriff von aussen erfordert andere Massnahmen als Datenmanipulation in der Buchhaltung durch Insider

Regelmäßige Maßnahmen

- Regelmäßige Systembackups und Restoretests setze ich voraus, da sowieso Bestandteil der hoffentlich vorhandenen Notfallplanung
- Sicherheitsupdates regelmäßig auf allen Maschinen, nicht nur bei als wichtig betrachteten Servern
- Regelmäßige Aktualisierung des Systeminventars
  - Inventarisierung Hardware, Software, Netzpläne
  - Signierung wichtiger Systemdateien (z.B. mit Tripwire oder AIDE) um Modifikationen zu erkennen
  - Liste von Dateien/Programmen mit riskanten Zugriffsrechten (z.B. SUID)
- Aktualisierung von Kontaktlisten / Kontaktaufbau zu
  - lokale Securityspezialisten
  - Ermittlungsbehörden

Protokollierungen

- Protokollierung aktueller Betriebssysteme nutzen
  - Was soll bzw. darf protokolliert werden?
  - Wie lange werden die Logs aufbewahrt ?
  - Wer darf die Logs einsehen ?
  - Unter welchen Voraussetzungen ?
- Protokolle nach Möglichkeit absichern
  - Verschlüsseln
  - Protokollierung verbergen (ggf. Analogie zum Rootkit nutzen)
  - Protokollierung ggf. auslagern
- zentrales Sammeln von Systemnachrichten, z.B. mit Syslogdaemon syslog-ng? (Linux/Unix)
- syslog-Software für Windows z.B. unter

Verwendung von Tools aus den Sysinternals

Anwendung	Beschreibung
AdInsight	Ein LDAP-Echtzeitüberwachungstool (Überwachung von AD)
DiskMon	Aufzeichnung von Festplattenaktivitäten
PortMon	Überwachung serieller und paralleler Schnittstellen
ProcDump	Beobachten von Lastspitzen, Erzeugung von Prozessdumps bei Absturz oder Exceptions
ProcessMonitor	Überwacht Prozess, Thread und DLL-Aktivitäten

Das ist nur eine (kleine) Auswahl möglicher Tools die eingesetzt werden können.
Wichtig: Bei deren Einsatz Datenschutzrecht (siehe diese VL) beachten

Beispiel: sysmon v15.15 vom 23. Juli 2024

Wichtigste Eigenschaften

- Anwendung der Sysinternals Suite
- Als Windows System Dienst und Treiber resisent auch zwischen Neuboots
- Monitoring und loggging von System Aktivitäten im Windows event log
  - Prozesse die generiert werden
  - Netzwerkverbindungen
  - Änderungen von Zeitstempeln an Dateien
  - Nutzung von Windows Event Collection or SIEM agents
  - Feststellung von Anomalien
- Achtung: Kein Schutzwerkzeug, auch wird keine eigene Analyse/Bewertung durchgeführt

Fähigkeiten von Sysmon im Detail (1)

Was ist das genau?

- Protokollierung Prozeßerzeugung mit vollständiger Komandozeile inklusive des Elternprozesses
- Aufzeichnung der Hashwerte von of process image files als SHA1, SHA256 or IMPHASH usw.
- Aufzeichung der Prozeß GUID ermöglicht Korrelation von Ereignissen selbst wenn Windows process IDs wiederverwendet
- Session GUID aller Ereignisse ermöglicht Korrelation von Ereignissen zu einer Loginsession
- Laden von Treibern oder DLLs inkl. Signatur und Hash
- Optional Protokollierung von Netzwerkverbindungen, inklusive Quellprozess, IP Adressen, ports, hostnames und port names.

Fähigkeiten von Sysmon im Detail (2)

- Erkennt Änderungen der file creation (oft von Malware zur Spurenbeseitung genutzt)
- Automatischer Reload der Konfiguration falls Änderungen in der Registry
- Filterung über Regeln möglich (Ein- und Ausschluß von Ereignissen)
- Setzt sehr früh im Boot Prozeß an um Aktivitäten fortgeschrittener kernel-mode malware zu protokollieren

Installation und Konfiguration von sysmon

Installation und Deinstallation

```
Sysmon.exe -i <configfile>
        [-h <[sha1|md5|sha256|imphash|*],...>]
        [-n (<process,...>)] [-l (<process,...>)]

Deinstallieren Sysmon.exe -u
```

Konfiguration

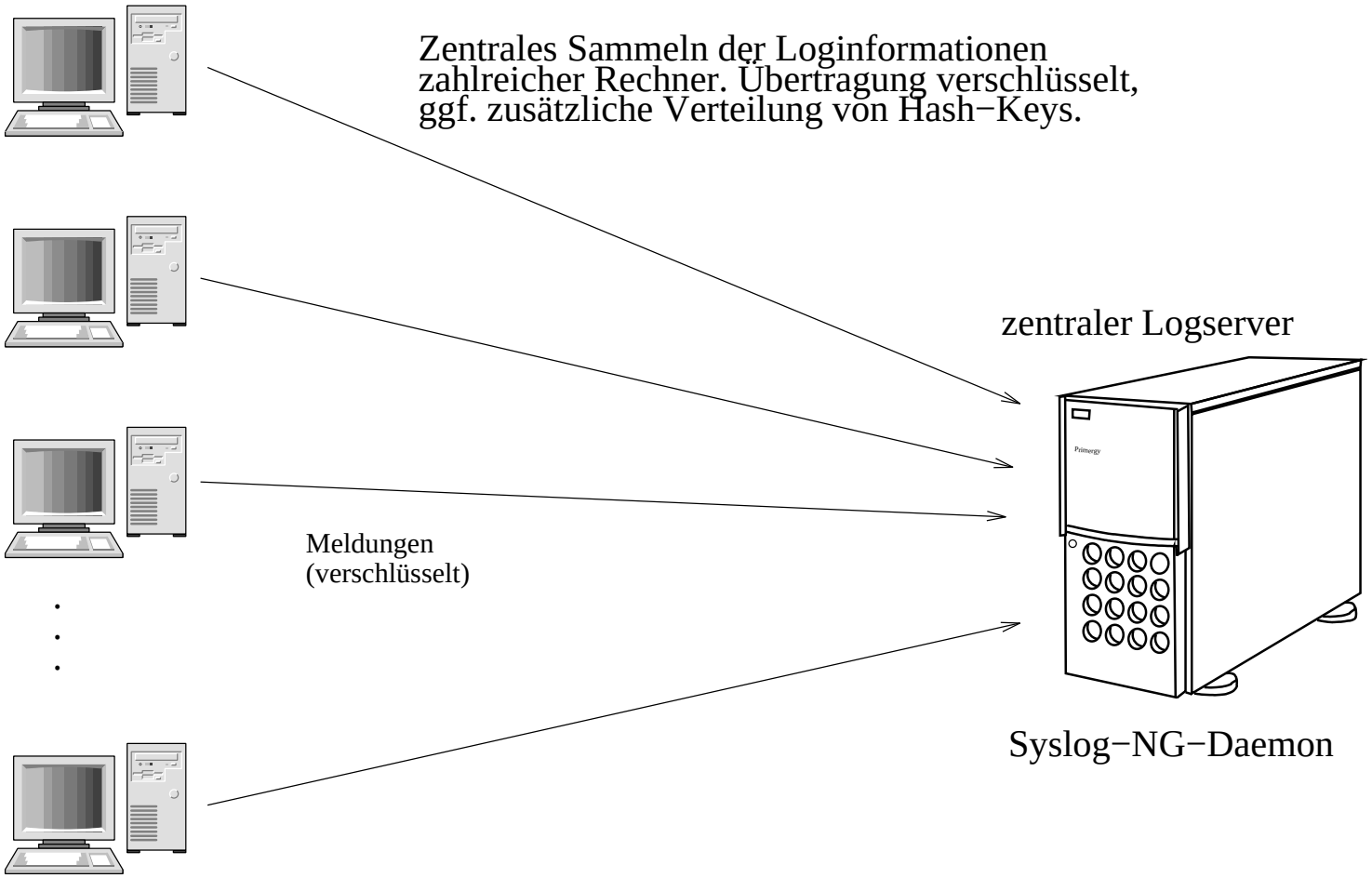
```
Sysmon.exe -c <configfile>
        [--|[-h <[sha1|md5|sha256|imphash|*],...>]
        [-n (<process,...>)] [-l (<process,...>)]]
```

Beispielkonfiguration

```
<Sysmon schemaversion="4.82">
  <!-- Capture all hashes -->
  <HashAlgorithms>*</HashAlgorithms>
  <EventFiltering>
    <!-- Log all drivers except if the signature -->
    <!-- contains Microsoft or Windows -->
    <DriverLoad onmatch="exclude">
      <Signature condition="contains">microsoft</Signature>
      <Signature condition="contains">windows</Signature>
    </DriverLoad>
    <!-- Do not log process termination -->
    <ProcessTerminate onmatch="include" />
    <!-- Log network connection if the destination port equal 443 -->
    <!-- or 80, and process isn't InternetExplorer -->
    <NetworkConnect onmatch="include">
      <DestinationPort>443</DestinationPort>
      <DestinationPort>80</DestinationPort>
    </NetworkConnect>
    <NetworkConnect onmatch="exclude">
      <Image condition="end with">iexplore.exe</Image>
    </NetworkConnect>
  </EventFiltering>
</Sysmon>
```

(Quelle: https://learn.microsoft.com/de-de/sysinternals)

Einsatz zentraler Logserver



Beispiel Syslog-NG (1) - Nachteile des klassischen Syslog

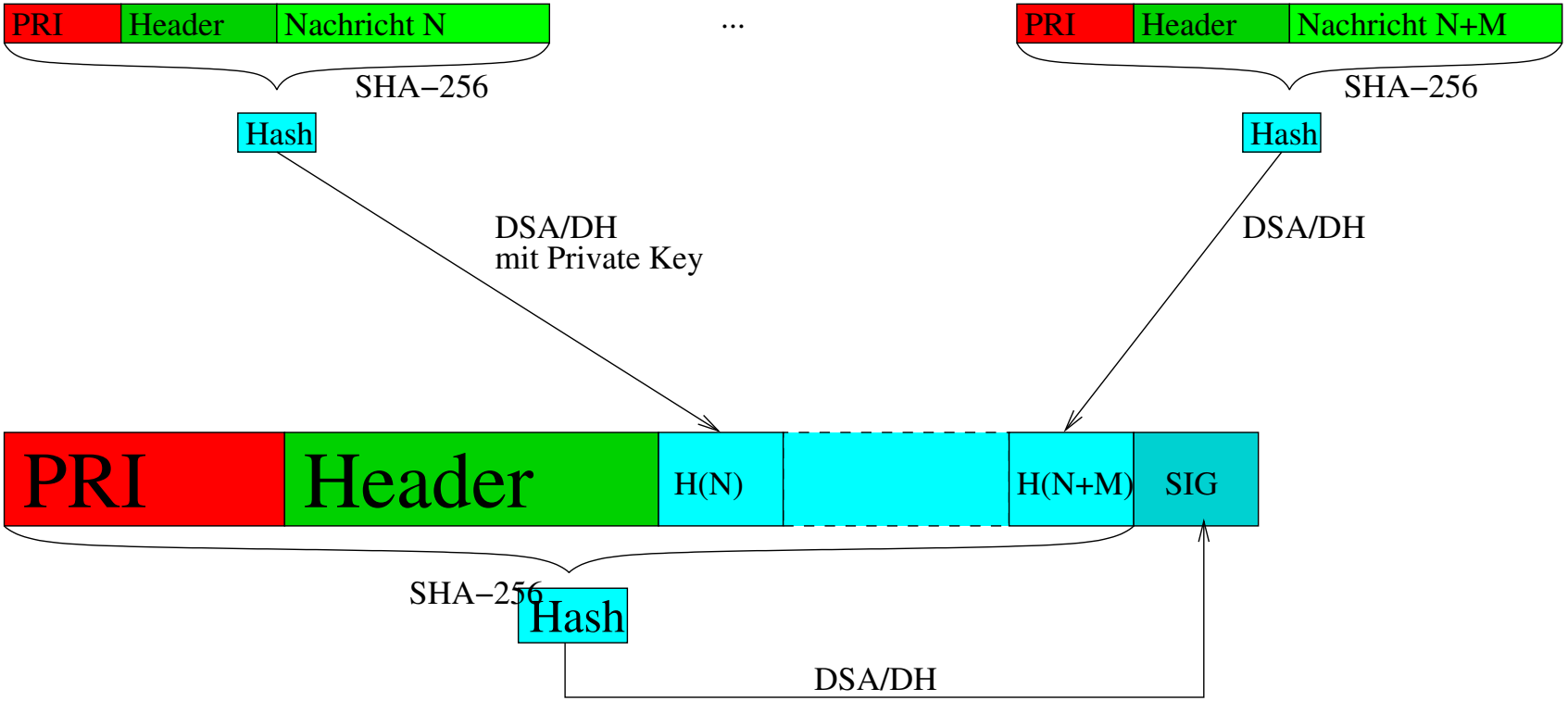
- keine Authentifizierung: Meldungen werden von jedem entgegengenommen (UDP-Port 514)
- Meldungen im Klartext.
- Unflexible Konfiguration (20 Herkunftsarten und 8 Prioritäten fest)
- Ursprüngliche Quelle geht beim durchreichen verloren, falls mehrere Loghosts beteiligt
- Verbindungslose Übertragung per UDP: Nachrichten gehen verloren
- Verwendung von Herkunft und Prioritäten uneinheitlich
- BSD-Syslog im Detail in RFC 3164 beschrieben

Beispiel Syslog-NG (2)

- Protokollmeldungen netzwerkweit einheitlich sammeln
- Zweck früher: läuft das System noch ?
- Zweck heute zusätzlich:
  - Früherkennung von Fehlern
  - Integrität der Systemmeldungen
  - im Angriffsfall wichtige Beweise sichern
- Verbindung auch über TCP/IP möglich
- Umfangreiche Filtermöglichkeiten
- Syslog-NG (von Balazs Scheidler) Ersatz für klassischen BSD-Syslog, hebt Nachteile der klassischen Version auf
- Alternativen z.b. SDSC Secure Syslog und Syslog Sign

Syslog-Sign

- Hashwerte für jede verschickte Nachricht
- Mehrere Nachrichtenhashes werden zusammengefasst in einem Paket verschickt



Incident Handling / Incident Response

Incident Handling

Eingesetzte Organisation, Prozesse und Techniken, um mit potentiell sicherheitsrelevanten Vorfällen umzugehen.

- Incident (Vorfall) absichtlich ohne Wertung
- Unterscheidung Betriebsstörung vs. Sicherheitsvorfall
  - Sammeln und bewerten aller Informationen
  - Falls Sicherheitsvorfall: Angriffsmethoden und Auswirkungen bewerten
- Ziele:
  - Minimierung der Störung von Geschäfts- oder Produktionsprozessen
  - Vollständige Beweissicherung und Dokumentation aller relevanten Daten

Entdeckung von Sicherheitsvorfällen

Entdeckungsproblematik

Viele Sicherheitsvorfälle werden in der Regel erst gar nicht entdeckt oder den Ermittlungsbehörden nicht gemeldet.

- Häufiges Problem: Unregelmäßigkeiten im IT-Betrieb werden bei den heutigen komplexen IT-Systemen als normal empfunden
- Tatsächliche Sicherheitsvorfälle haben oft zu ähnliche Auswirkungen zu Systemausfällen oder Anomalien im Regelbetrieb
- Anzeichen von Angriffen häufig unspektakulär
- Angriffe oft nur durch Zusammenführung mehrerer Anomalien bemerkbar

Hinweise aus Netzwerkverkehr

- Überwachung des eigenen Netzwerkverkehrs kann wichtige Hinweise zu erfolgten Angriffen liefern
- Worauf ist zu achten?
  - Ungewöhnliche hohe Netzlasten des ein- oder ausgehenden Datenverkehrs
  - Hohe Netzlast ist in Abhängigkeit von Diensten zu betrachten (z.B. Anstieg von ICMP-Paketen nach aussen)
  - Viel Verkehr auf ungewöhnlichen Ports
  - z.B. Anstieg von Paketen hoher Entropie nach aussen → Erklärung
  - Ungewöhnliche Topologie des Netzwerkverkehrs ?
  - Stattfindender „Denial of Service“ oft Tarnung für tatsächlichen Angriff
  - Hohe Anzahl von Regelverletzungen auf Firewall
- Am besten durch ein gutes IDS (Intrusion Detection System) automatisieren!

Wozu braucht man das?
Wie wird es programmiert

Mögliche Hinweise auf Servern

Allgemeine Hinweise:

- Unbekannte (System-)Prozesse oder Kernelmodule
- Unbekannte Dateien oder Verzeichnisse, häufig an ungewöhnlichen Stellen im Dateisystema (z.B. Ausführbare .-Datei in `/dev/usb/`)
- Unbekannte Benutzer (v.a. Nutzer mit Adminrechten)
- Ungewöhnliche Systemlast, häufig z.B. auch ausserhalb der Geschäftszeiten
- Tätigkeiten von Nutzern ausserhalb Bürozeiten
- Ausfall oder Verlangsamung bestimmter Dienste
- Ungewöhnliche Systemmeldungen in Logs

Problematik:

- Vermehrter Einsatz moderner Rootkits
- Aber: Auch Rootkit benötigt Ressourcen!

Beispiel: RootkitRevealer (Sysinternals Suite)

- Leistungsfähige SW zur Rootkiterkennung unter MS Windows
- Erkennt z.B. AFX, Vanquish und HackerDefender
- Nutzt Unstimmigkeiten von Registrierung- und Dateisystem-APIs
- Erkennung vieler Benutzermodus- und Kernelmodusrootkits
- Erkennt z.B. AFX, Vanquish und HackerDefender
- Natürlich kann auch dieses Tool nicht alle Rootkits erkennen!

KLassifizierung von Rootkits:

- Residente Rootkits überstehen Neustart
- Speicherbasierte Rootkits durch Reboot entfernbar
- Benutzermodusrootkits verändern windowseigene Benutzer-API (Schnittstelle Benutzerclient zu Kernelmodediensten)
- Kernelmodusrootkits können beliebig leistungsfähig sein

Hinweise durch Mitarbeiter oder von Extern

- Gemeldeten Unregelmäßigkeiten nachgehen:
  - Bestimmte Anwendungen sind plötztlich eingeschränkt oder gar nicht mehr verfügbar
  - Netzwerkressourcen sind eingeschränkt verfügbar
  - Berechtigungen sind eingeschränkt oder erweitert
- Hinweise durch Ermittlungsbehörden oder Provider
  - z.B. eigene IP-Adressen tauchen bei DNS-Angriffen auf
  - Urheberrechtsverstöße mit eigenen IP-Adressen
  - umfangreiche Netzwerkscans aus dem eigenen Netz
- Hinweise auf Fehlbuchungen
- Hinweise auf Fremdnetze in Netzwerkumgebung

Informatik als forensische Wissenschaft

Digitale Spuren in der Theorie

- Digitale Spur ist zentraler Begriff in der forensischen Informatik
- Wie wir gesehen haben, bestehen wesentliche Unterschiede zur physischen Spur
- Digitale Rechner codieren alle Informationen binär und kennen nur eindeutig unterscheidbare Zustände
- Ein Computer befindet sich also zu jedem Zeitpunkt in einem genau definierten diskreten Zustand
- Zustand ist im Prinzip kopierbar, da endlich
- Ein Computer als geschlossenes System kann daher als Zustandsautomat angesehen werden.

Zustandsautomat

Sie kennen den Zustandsautomat bereits aus der theoretischen Informatik.

Definition Zustandsautomat

Ein Zustandsautomat hat vier Bestandteile:

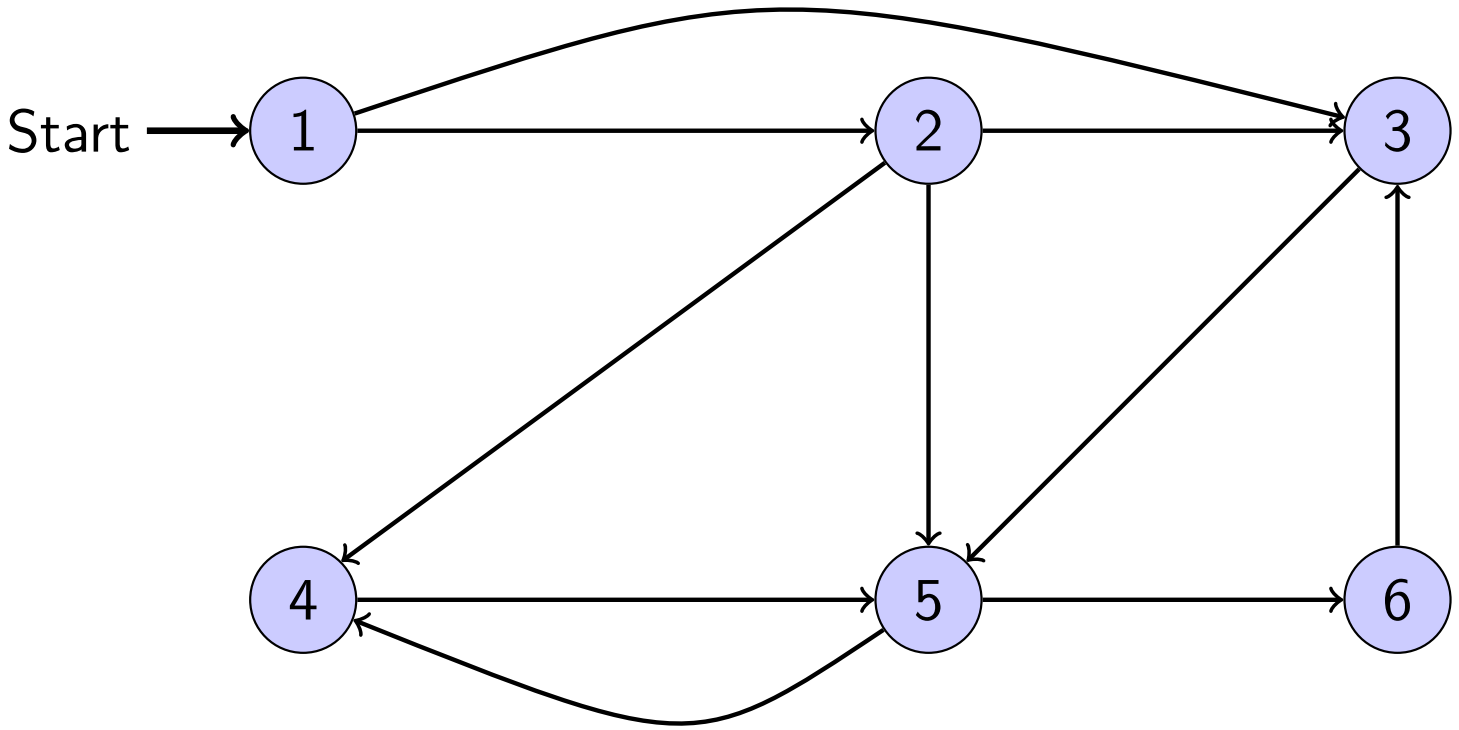
- Eine (endliche) Menge Z von Zuständen
- Einer der Zustände $s \in Z$ ist als Startzustand gekennzeichnet
- Eine Zustandsübergangsfunktion δ

automatisch weiter rotiert

Außerdem wird angenommen, daß der Automat lebendig ist. Das bedeutet, dass er nicht in einem Zustand verharrt, der nicht als Endzustand gekennzeichnet ist.

Ein Zustandsautomat kann auch sehr gut graphisch dargestellt werden.

Graphische Darstellung eines einfachen Zustandsautomaten



In der Realität viel mehr Zustände

- Ein (realer) Computer hat natürlich viel mehr Zustände
- z.B. 4GB DRAM ensprechen $2^{4 \cdot 1024^3}$ Zuständen
- z.B. 20 64-Bit CPU-Register entsprechen $2^{64^{20}}$ Zuständen
- Analog gelten ähnliche Berechnungen für alle anderen vorhandenen Speicher und HW-Register in Custom-Chipsätzen und Graphikkarten

In der Praxis:

- Es ändern sich pro Bearbeitungsschritt nur wenige Speicherzellen
- Wichtige Fragestellung: Auf welchen Wegen (Zustandsübergängen) ist es möglich vom Zustand A zum Zustand B zu kommen
- Ist B überhaupt vom Zustand A aus erreichbar
- Rückschluss: Was sind mögliche Ausgangszustände von B?

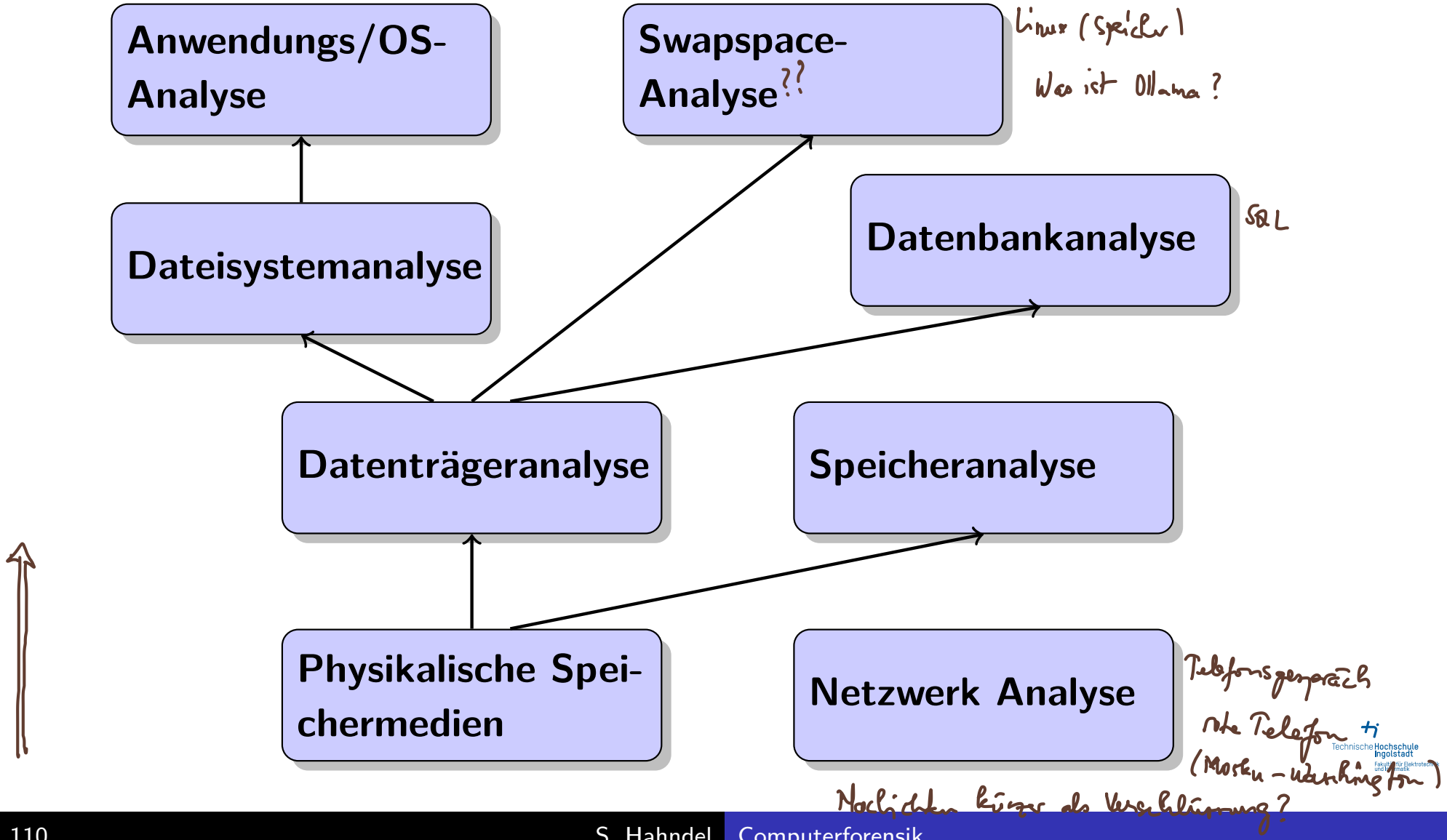
Theoretische Überlegungen / Betrachtung einfacher Datenstrukturen

- Ausgangspunkt: Betrachtung einfacher Datenstrukturen
- Diese werden mit bekannten Algorithmen „modifiziert“
- Annahme: Jede Änderungsoperation (z.B. einfügen) speichert Zeitstempel im Datenknoten
- Fragestellung: Welche Manipulationen an Zeitstempeln lassen sich anhand des Zustands der Datenstruktur erkennen?

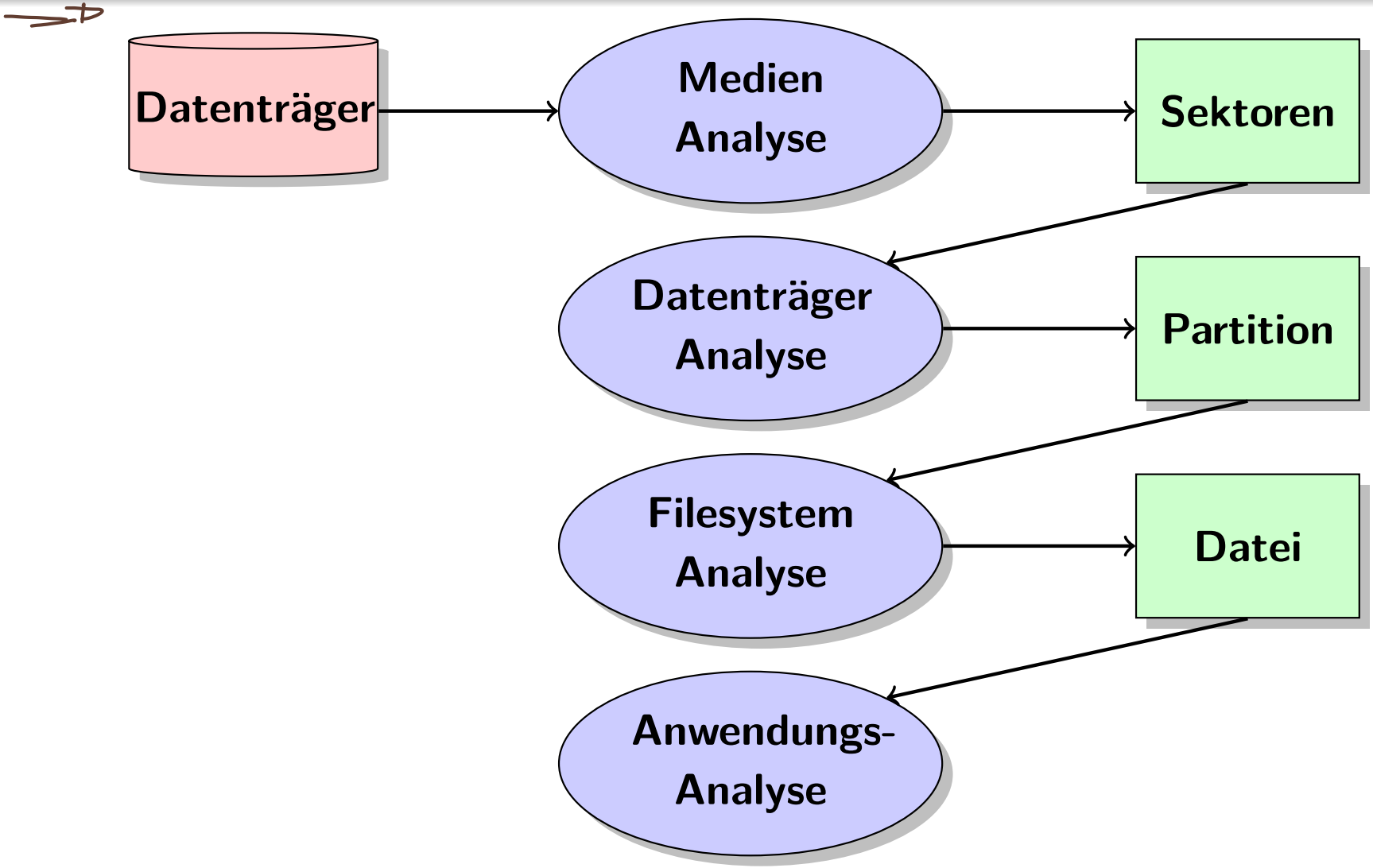
Betrachten Sie dazu folgende Datenstrukturen:

- Einfach verkettete Listen
- Stapel oder Queues
- Baumstrukturen: Sortierter Binärbaum mit nicht nicht balancierendem / balancierendem Einfügen (z.B. AVL-Baum) ??

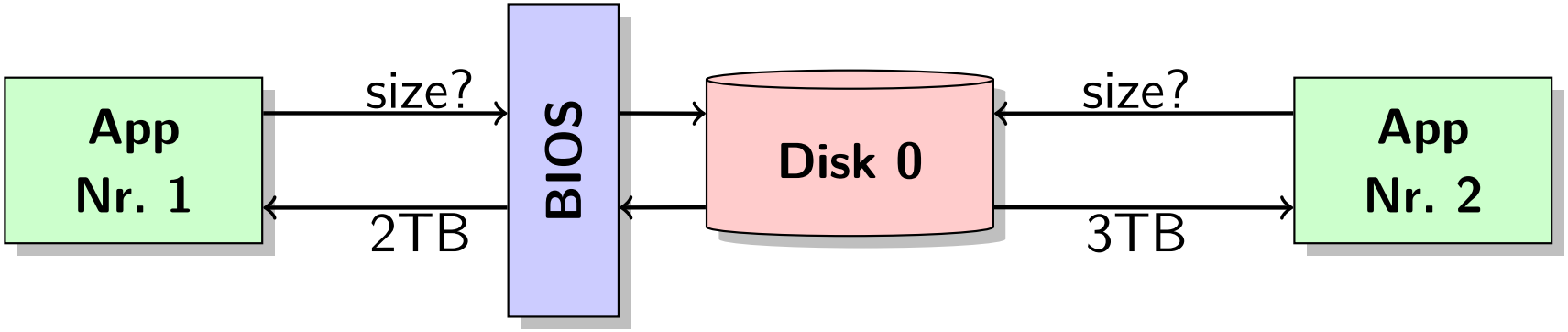
Analyselevel basierend auf digitalen Daten



Analyselevel basierend auf digitalen Daten



Direktzugriff vs. BIOS



Die Entscheidung oder „Jetzt wirds ernst!“

Annahme

Anomalien sind höchstwahrscheinlich auf einen Sicherheitsvorfall zurückzuführen, da andere Ursachen ausgeschlossen wurden.

Welche Fragen sind zu stellen?

- Welche Systeme könnten noch betroffen sein?
- Wie geschäftskritisch sind diese Systeme?
- Wie lange liegt der Vorfall voraussichtlich zurück?

Darauf aufbauend erste wichtige Entscheidung:
Live Response oder Post Mortem Analyse der betroffenen Systeme ?

Wann ist Live Response sinnvoll?

Vorraussetzungen:

- Der Vorfall liegt nicht lange zurück
- Der Rechner wurde in der Zwischenzeit nicht gebootet
- Der Rechner enthält wichtige flüchtige Daten die beim ausschalten verloren gehen, z.B. gemountetes Truecrypt-FS mit unbekanntem Paßwort

Vorteile:

- Aktuelle Ereignisse lassen sich ggf. rekonstruieren
- Flüchtige Daten wie Prozessstrukturen, Netzwerkverbindungen gehen nicht verloren

Entscheidener Nachteil:

- Eingriffe in das Livesystem verändern den Systemzustand zwangsläufig!

Wann ist Post-Mortem-Analyse das Mittel der Wahl?

Vorraussetzungen:

- Der Vorfall liegt lange zurück
- Der Rechner wurde in der Zwischenzeit gebootet
- Oder: Täter ist aktuell online, könnte Spuren verwischen

Vorteile:

- Am wichtigsten: Wir haben alle Zeit der Welt!
- Wir können bei richtiger Vorgehensweise nichts kaputt machen

Entscheidener Nachteil:

- Ggf. wichtige flüchtige Informationen des Livesystem gehen verloren, falls Entscheidung zu PM-Analyse ungünstig.

Häufige Fehler nach einem bemerkten Vorfall

Wie kann man ein Backup auf Windows-Laptop machen??

- Ein Admin bootet neu oder spielt gleich ein Backup ein
- Ein Admin versucht das System schnell wieder zum laufen zu bringen
- Ein Admin löscht „aus Sicherheitsgründen“ verdächtige Dateien und Verzeichnisse
- Ein Mitarbeiter oder Privatperson löscht für ihn peinliche Dateien, nachdem er ein Schadprogramm bemerkt hat.

Literaturempfehlungen I

- Brian Carrier
  File System Forensic Analyses, Addison-Wesley, 2005.
- Andreas Dewald, Felix C. Freiling,
  Books on Demand, 2011.
- Alexander Geschonneck
  Computer Forensik - iX Edition, 6. erweiterte Auflage, 3. April 2014.
- Dan Farmer, Wietse Venema
  Forensic Discovery. Addison-Wesley, 2005
- Lorenz Kuhlee und Victor Völzow
  Computer Forensik Hacks O´Reilly Hacks Series, 2012.